

On the server side, *getcookie.php* can now retrieve the session data from the cookie, and the attacker can impersonate the user.

How to prevent XSS attacks

XSS can only be prevented by carefully validating and sanitising all inputs thought to be insecure. Never trust user data or data coming from any other unknown sources. Every bit of data must be validated on input and escaped on output. This is the first step to protecting oneself against XSS. In order to implement security measures that prevent XSS attacks, special attention should be paid to data validation, data sanitisation, and output escaping.

Data validation ensures that your application is running with the correct data. If your script expects an integer as the user input, then any other type of data will be discarded. Every piece of user data must be validated when it is received to ensure it is of the correct type, and discarded if it doesn't pass the validation process.

Data sanitisation focuses on manipulating the data to make sure it is safe by removing any unwanted characters from the data and normalising it to the correct form. For example, if you are expecting a plain text string as user input, you may want to remove any HTML mark-up from it.

Proper escaping should be performed on the data before presenting it to the user. This prevents the browser from applying any unintended meaning to any special sequence of characters that may be found. If you host a website, you will want it to be hacker-proof, and so you will need to perform checks for these vulnerabilities. Fortunately, we have tools to perform these tasks for us. Given below are some of the open source tools that will help us in detecting the various flaws in our websites.

XSSer: This is an open source penetration testing tool that automates the process of detecting and exploiting XSS injections in any website.

<http://xsser.sourceforge.net/>

Zaproxy: This is an easy to use integrated penetration testing tool for finding vulnerabilities in Web applications.

<http://code.google.com/p/zaproxy/>

Firing Range: This is a test bed for Web application security scanners and provides synthetic, wide coverage for an array of vulnerabilities. It can be deployed as a Google App Engine application.

<https://github.com/google/firing-range>

Nikto Web Scanner: This is a Web server scanner that tests Web servers for dangerous files/CGLs, outdated server software and other problems. It performs generic and server type specific checks.

<https://cirt.net/Nikto2>

<https://github.com/sullo/nikto>

Vega: This is a free and open source scanner and testing platform to test the security of Web applications. Vega can help you find and validate SQL Injection, XSS, inadvertently disclosed sensitive information, and other vulnerabilities.

<https://subgraph.com/vega/>

Grabber: This is a nice Web application scanner that can detect many security vulnerabilities in Web applications. It performs scans and indicates where the vulnerability exists.

<http://rgaucher.info/beta/grabber/>

Source code on Github: <https://github.com/neuroo/grabber>

Wapiti: This is also a good Web vulnerability scanner that lets you test the security of your Web applications. It performs black-box testing by scanning Web pages and injecting data.

<http://wapiti.sourceforge.net/>

WebScarab: This is a Java-based security framework for analysing Web applications using the HTTP or HTTPS protocols. With available plugins, you can extend the functionality of the tool, which works as an intercepting proxy. So, you can review the request coming to your browser and the response going to the server.

Source code on Github: <https://github.com/OWASP/OWASP-WebScarab>

Ratproxy: This is also an open source Web application security audit tool, which can be used to find security vulnerabilities in Web applications.

<http://code.google.com/p/ratproxy/>

X5s: This is also a Fiddler add-on, which aims to provide a way to find cross-site scripting vulnerabilities. This is not an automatic tool. So, you need to understand how encoding issues can lead to XSS.

<http://xss.codeplex.com/> 

By: Chetan Tarale

The author is an independent programmer and is interested in application security, reverse engineering and penetration testing. He also loves to explore GNU/Linux and emerging open source technologies.

THE COMPLETE MAGAZINE ON OPEN SOURCE

OpenSource
ForYou

Your favourite Magazine on Open Source is now on the Web, too.

OpenSourceForU.com

Follow us on Twitter@LinuxForYou